Risk Assessment Log: Study Matching App

Risk ID	Risk Description	Likelihood	Impact	Risk	Mitigation strategy	Responsible Person
1	GDPR/ Data privacy Non-compliance: Improper handling or storage of individuals personally identifiable information gathered through profile data and surveys.	Medium	High	**High**	Use anonymous survey responses, collect only profile data, which is needed for the studies, store data on secure university approved servers to ensure integrity of the data, use synthetic data for prototype testing and create a clear privacy notice	Cyber Consultant
2	Lack of ethics approval: Launching surveys or recruiting participants before formal ethical clearance is granted.	Medium	High	**High**	Prioritise submitting the ethics application as one of the first milestones, to ensure there are no delays.	Project Manager
3	Low recruitment turnout: Inability to attract or secure enough participants and researchers for the app to be useful and to gather meaningful feedback.	High	Medium	**Medium**	Broaden level of recruitment (social media, campus flyers, talking to students on campus), seed the app with a few example studies, offer small incentives if needed and keep the surveys short.	Project Manager
4	Selection and sampling bias: Surveys only capture feedback from a small demographic of students	Medium	High	**High**	Actively target diverse user groups, design accessible survey formats and critically evaluate the sample representation during analysis.	Designer

	(e.g. Tech-savvy students) can skew results making them statistically biased.					
5	Survey Fatigue: Participants abandon the surveys midway through as they are too long, complex, boring or poorly structured.	High	Medium	**Medium**	Keep the surveys under 10 minutes, pilot-test questions with members of the group first, and use clear, simple language.	Designer
6	Version control and Data loss: Loss of Code, documentation, or survey data due to poor file management.	Low	High	**Medium**	Enforce mandatory use of Git/GitHub for code repositories and cloud storage (OneDrive) for shared documents.	Developers
7	Technical Bugs and Compatibility Issues: The prototype app fails to work smoothly on different operating systems (iOS/ Android).	Medium	High	**High**	Conduct thorough troubleshooting and testing before user deployment.	Developers
8	Unequal Workload/ Group Conflict: Miscommunication or uneven distribution of tasks among group members leading to conflict.	Low	High	**Medium**	Establish a team charter, outline clear individual roles and deadlines, in a project management tool such as Excel, and hold weekly check-ins so that everyone is at the same level.	Project manager
9	Time management delays: Falling behind due to unexpected bottlenecks during development.	High	Medium	**Medium**	Build a buffer period into the project schedule and identify critical tasks which need immediate attention.	Project manager

10	App Security vulnerabilities: Data breach of survey/ participant data: unauthorised access to stored responses or participants personal information.	Medium	High	**High**	Perform Security code reviews, enforce HTTPS/ TLS encryption across all API endpoints and survey data pathways. Store data on secure university approved servers and limit access to team members only. Encrypt data at rest (AES-256) and in transit.	Cyber Consultant
11	Access Control and authentication: Insecure role-based access control, weak passwords, or poor session handling, allowing for attackers to take over user accounts.	Medium	High	**High**	Enforce strict role-based access control (RBAC), ensure backend routes explicitly verify users' permissions before returning any sensitive data. Enforce a strong password policy, use multi-factor authentication, hash stored passwords, limit login attempts and set session timeouts.	Cyber Consultant/ Developers
12	Lack of logging and monitoring: Security incidents go undetected because there's no trail of access or changes viewable by admins.	Medium	Medium	**Medium**	Enable Access logs on the backend and review them during the weekly check-ins.	Developers
13	Anonymisation failure: Responses that are supposed to be anonymous can be linked back to individuals (e.g. small demographic groups or free-text answers).	Medium	High	**High**	Avoid collecting unnecessary personal identifiable information, group small categories together (e.g. age bands instead of exact ages), avoid identifying free-text responses and show researchers only anonymous data.	Designer

14	Matching Errors and bias: The matching logic wrongly includes or excludes people, or criteria unfairly excludes groups.	Medium	High	**High**	Test matching logic on an array of criteria and cases, show researchers a preview of who their criteria include and exclude and include a criteria review step to ensure participants are eligible.	Developers
15	Withdrawal, data erasure and retention: Unclear handling of account deletion, consent per study and how long data is stored.	Medium	High	**High**	Provide a delete-account function, set a retention policy and capture consent per study.	Cyber Consultant
16	Special category data in profiles: Profiles may hold sensitive data such as health or ethnicity needed for matching, which requires extra protection under UK GDPR.	Medium	High	**High**	Only collect data which is needed for a study, obtain explicit consent and store data on a secure university-approved server.	Cyber Consultant
17	Profile gaming: Participants repeatedly edit their profile to reveal hidden criteria or give false answers to qualify for more studies, reducing the data's validity.	High	Medium	**Medium**	Rate-limit profile edits, log any profile changes and let researchers add screening questions.	Developers

Scoring Key-

	Low impact	Medium impact	High impact
High likelihood	Low	Medium	High
Medium likelihood	Low	Medium	High
Low likelihood	Low	Low	Medium